Resumen 1_Sesión 1_Bienvenidos_Actividad de aprendizaje 1_Realizar la valuación de los activos de la organización_23_04_2026

Es importante los ingresos a las sesiones ya que despejaran dudas referentes al tema de la unidad y del manejo de la plataforma.

Resumen de la sesión en línea.

Inicio la primera sesión en línea dando la bienvenida al proceso formativo y presentación del instructor, siendo las 08: 00 am de día 23 de abril. Se comparte la agenda de la sesión en línea la cual genera un recorrido por el ambiente de aprendizaje, evidenciando el cronograma de actividades de la primera unidad junto con las fechas de cierre de cada unidad del curso. Notificamos las actividades iniciales a realizar, Se comparte la guía de aprendizaje en la cual se enfatiza las actividades a ejecutar. Se identifica los medios en los cuales los aprendices pueden contactar al instructor como lo son: Foro de dudas e inquietudes, mensajería interna, chat, sesiones en línea y se otorga el número de celular del instructor.

METODOLOGÍA:

Estudio independiente (Autónomo): *Este estudio se realizará de manera independiente en el ambiente virtual de enseñanza.*

Para esto lo invitamos a seguir las siguientes indicaciones:

- ✔ *Dedicar el tiempo necesario para leer el material de formación y para el desarrollo de las actividades aprendizaje.*
- ✔ *Consultar constantemente página principal, anuncios y los foros de discusión.*
- ✔ *Mantener una constante comunicación con su tutor, a través de los espacios disponibles (Correo, mensajería interna o WhatsApp)*

Cronograma de actividades

UNIDAD TEMÁTICA O ACTIVIDAD DE APRENDIZAJE	RESULTADO DE APRENDIZAJE (RAP)	CONFERENCIAS WEB (FECHA – HORA)	EVIDENCIAS DE APRENDIZAJE	FECHAS DE ENTREGA	
				INICIA	FINALIZA
Actividades iniciales	**N/A**	**N/A**	Participación en el "**Foro social**", n***o calificable.***	20/04/2026	27/04/2026
			Realizar la "**Actualización de datos del aprendiz**", según indicaciones, ***no calificable.***	20/04/2026	27/04/2026
Actividad de aprendizaje 1 Realizar la valuación de los activos de la organización.	**220501108-01.** Valorar activos de información de acuerdo con métodos y criterios técnicos de evaluación	23/04/2026 a las 08:00 AM	**Evidencia de producto** AA1_EV01_Informe del análisis y valuación de activos	20/04/2026	27/04/2026

Introducción

Uno de los aspectos fundamentales en la era de la tecnología, corresponde al uso adecuado de la información y manejo de los datos a través de redes informáticas, es por ello por lo que resulta relevante el comprender los aspectos y principios básicos de la seguridad de la información y su evolución a la ciberseguridad como una práctica necesaria en defensa y protección de los datos y dispositivos informáticos de ataques, espionaje y robo de datos. De igual forma se establecerán a través del presente material formativo los requerimientos, normas y estándares internacionales más utilizados y recomendados.

Ciberseguridad

Definición

La ciberseguridad es el conjunto de herramientas, políticas, conceptos de seguridad, salvaguardas de seguridad, directrices, métodos de gestión de riesgos, acciones, formación, prácticas idóneas, seguros y tecnologías que pueden utilizarse para proteger los activos de la organización y los usuarios en el ciberentorno. Los activos de la organización y los usuarios son los dispositivos informáticos conectados, los usuarios, los servicios/aplicaciones, los sistemas de comunicaciones, las comunicaciones multimedios, y la totalidad de la información transmitida y/o almacenada en el ciberentorno. La ciberseguridad garantiza que se alcancen y mantengan las propiedades de seguridad de los activos de la organización y los usuarios contra los riesgos de seguridad correspondientes en el ciberentorno. ***(Unión Internacional de Telecomunicación, 2010).***

Ciberseguridad

El concepto de ciberseguridad se ha convertido en un estándar y en una necesidad en todas las organizaciones puesto que cada vez más y con mayor frecuencia se recurre al uso de las tecnologías de la información y las comunicaciones para apalancar los procesos operativos y core del negocio, el desarrollo y evolución de la tecnología nos lleva a hacer uso de servicios como internet, la interconexión entre sedes y con mayor frecuencia la utilización de tecnologías de computación en la nube lo que necesariamente obliga a las empresas a proteger sus recursos y su información del acceso no autorizado y de todas las posibles amenazas de las cuales pueden ser víctimas.



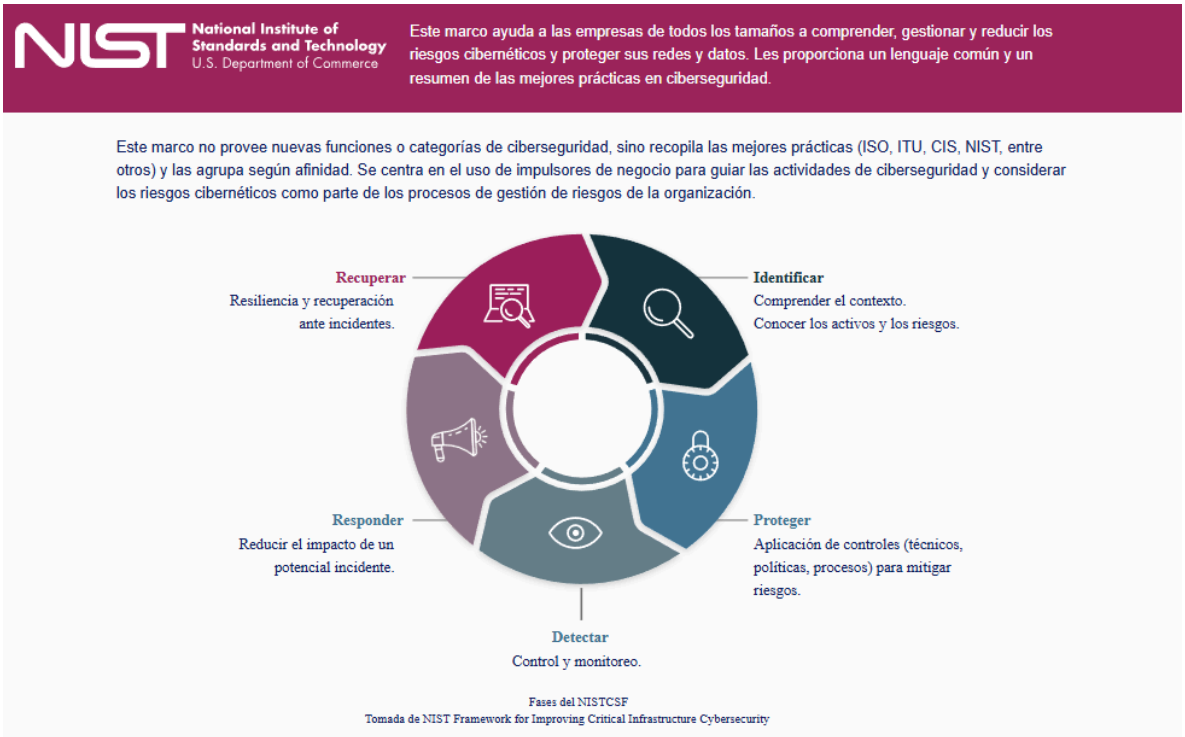
Marcos de referencia

Los ataques cibernéticos son cada vez más comunes y frecuentes, como se mencionó anteriormente debido a la inmersión de la tecnología en los procesos empresariales, es claro que debemos proteger nuestros recursos y activos, la pregunta es ¿Cómo empezar?, es ahí donde cobra importancia los marcos de referencia que se han venido desarrollando y adoptando, estos marcos suministran información valiosa y útil en el diseño de procesos de control y mitigación de riesgos de ciberseguridad.

Si bien se debe elegir un marco y trabajar con él, son solo una referencia y no una solución definitiva porque también es importante el enfoque del análisis de riesgos del cual hablaremos más adelante, cada marco propone una serie de controles, se debe elegir cuales son aplicables a mi entorno y si se llegase a requerir hacer adopción o ajustes de otros marcos de referencia.

A continuación, se definen los marcos de referencia más utilizados y de mayor desarrollo incluyendo algunos propósitos particulares para su adopción:

***NIST CSF** (National Institute of Standards and Technology - Cybersecurity Framework) - Marco de Ciberseguridad del Instituto Nacional de Estándares y Tecnología.*

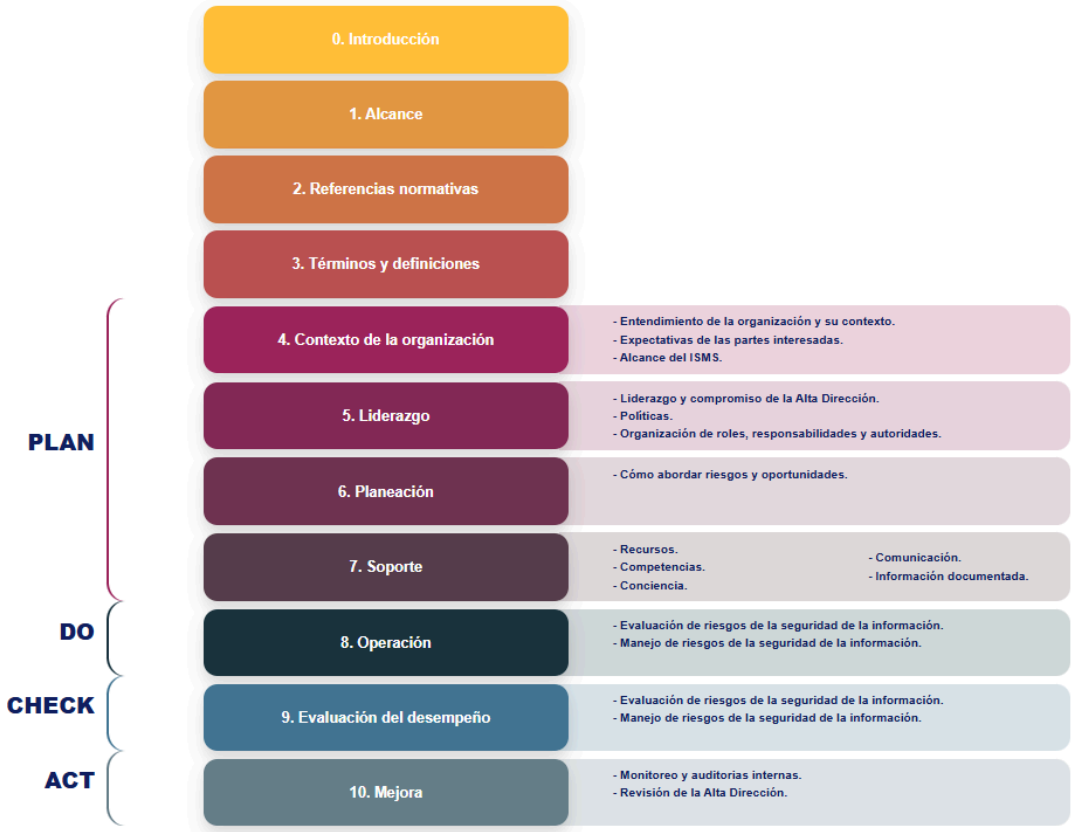


Fases del NISTCSF
Tomada de NIST Framework for Improving Critical Infrastructure Cybersecurity

ISO / IEC 27001: 2013

Este marco, creado y publicado por la Organización Internacional de Normalización (ISO), es un marco general que funciona bien para empresas de diversos tamaños en una variedad de industrias. Es similar al NIST CSF. El marco es respetado y ampliamente conocido internacionalmente. El enfoque de ISO 27001 es la protección de la confidencialidad, integridad y disponibilidad de la información en una empresa.

Su filosofía se basa en la gestión de riesgos: investigar dónde están y luego tratarlos de manera sistemática.



Fases y Actividades ISO 27001:2013

Tomada de https://www.magazcitum.com.mx/?p=2397#.X58QqYhKhP

COBIT *(Objetivos de control para información y tecnologías relacionadas. En inglés Control Objectives for Information and related Technology)*

COBIT fue desarrollado por ISACA, una organización global independiente sin fines de lucro que se enfoca en el gobierno de TI. Este marco es similar al marco de NIST e ISO, ya que es un marco más general que la mayoría de las organizaciones pueden usar.

Es una guía de mejores prácticas, dirigida al control y supervisión de TI. Cuenta con una serie de recursos que pueden servir de modelo de referencia para la gestión de TI, incluyendo objetivos de control, mapas de auditoría, herramientas para su implementación y una guía de técnicas de gestión.

HITRUST CSF *(Health Information Trust Alliance - Cybersecurity Framework)*

HITRUST CSF fue desarrollado por Health Information Trust Alliance (HITRUST) y es el marco de seguridad más adoptado en la industria de la salud

de los Estados Unidos. HITRUST originalmente desarrolló su CSF (Cybersecurity Framework en español Marco de ciberseguridad) para enfocarse en elementos clave y riesgos inherentes a la industria de la salud, como las consideraciones de HIPAA (Ley de Responsabilidad y Portabilidad de Seguros de Salud), pero desde entonces han actualizado el marco con controles más amplios que se aplicarían a cualquier organización.

CSA Cloud Controls Matrix

La Cloud Controls Matrix fue desarrollada por Cloud Security Alliance (CSA) específicamente para los proveedores de la nube. La estructura del almacenamiento de datos en la nube conlleva riesgos únicos que requieren controles de seguridad específicos, que se establecen en este marco. La matriz de controles de la nube se actualiza con frecuencia y es útil para los proveedores de la nube de cualquier tamaño.

CSA CCM fortalece los entornos de control de seguridad de la información existentes al enfatizar los requisitos de control de seguridad de la información empresarial, reduce e identifica las amenazas y vulnerabilidades de seguridad consistentes en la nube, proporciona seguridad estandarizada y gestión de riesgos operativos, y busca normalizar las expectativas de seguridad, taxonomía y terminología de la nube.

Seguridad de la información

Generalidades

El concepto de seguridad de la información significa proteger la información y los sistemas de información de un acceso, uso, divulgación, alteración, modificación, lectura, inspección, registro o destrucción no autorizados. Soriano, M. (2014).

Si bien son complementarias se debe diferenciar los conceptos de seguridad de la información, seguridad informática y seguridad en la red.

Principios

Como se mencionó anteriormente la seguridad de la información se centra en garantizar lo que en el mundo de seguridad se conoce como la triada conocida por sus siglas CIA, que nada tienen que ver con una famosa agencia de estados unidos, se le da este nombre ya que corresponde a las iniciales de los principios que sustentan la seguridad de la información: confidencialidad, integridad y disponibilidad.



Políticas de seguridad

*Para entender los términos sobre **políticas de seguridad**, es necesario definir el concepto más general de política, siendo esta una declaración de alto nivel que describe la posición de la entidad sobre un tema específico.*

Ahora, si le adicionamos el concepto de seguridad por supuesto se refiere a la declaración de alto nivel donde la organización fija una posición frente a la necesidad de contar con un sistema de gestión de seguridad de la información que identifique el qué, de quién y cómo se deben proteger los recursos o activos tecnológicos necesarios para el cumplimiento del core de la empresa.

En términos más generales "las políticas de seguridad son un conjunto de reglas, normas y protocolos de actuación que se encargan de velar por la seguridad informática de la empresa. Se trata de una especie de plan realizado para combatir todos los riesgos a los que está expuesta la empresa en el mundo digital. De esta forma mantendremos nuestra organización alejada de cualquier ataque externo peligroso". (Caurin, 2018).

Estándares y normas de referencia

Existen varios estándares de seguridad informática, iniciando por el grupo de estándares ISO/IEC 27000 que integran un sistema de administración de seguridad de la información (information security management system ISMS) el cual está enfocado en la seguridad de la información bajo un explícito control administrativo de la misma.

El ISO 15408 es un estándar desarrollado en lo que se conoce como "Criterio Común" y permite que diferentes aplicaciones de software puedan ser integradas y probadas en una forma o manera segura.

El RFC 2196 es memorándum publicado por el Internet Engineering Task Force para el desarrollo de políticas y procedimientos de seguridad para sistemas de información conectados a Internet; proporciona una amplia y general visión de la seguridad de la información incluyendo la seguridad de la red, respuesta a incidentes o las políticas de seguridad. El documento es muy práctico y centrado en el día a día de las operaciones.

Para el campo industrial, se inició en el año 2007, con el grupo de trabajo de la International Society for Automation (ISA), el estándar ISA-99 denominado Security for Industrial Automation and Control Systems con la publicación del estándar ANSI/ISA-99.00.01-2007 Security for Industrial Automation and Control Systems: Concepts, Terminology and Models, en conjunto con el reporte técnico ANSI/ISA-TR99.00.01-2007, Security Technologies for Manufacturing and Control Systems. A principios de 2009, fue aprobado por ANSI el estándar ANSI/ISA-99.02.01-2009, Security for Industrial Automation and Control Systems: Establishing an Industrial Automation and Control Systems Security Program. Finalmente, en el año 2010, se cambió por el estándar ISA/IEC 62443 para alinear la numeración de la documentación del estándar con los estándares correspondientes de la International Electrotechnical Commission (IEC).

Riesgos y mecanismos de valuación

El riesgo es la posibilidad de que una amenaza se produzca, dando lugar a un ataque sobre un recurso o servicio tecnológico. Esto no es otra cosa que la probabilidad de que ocurra el ataque por parte de la amenaza.

Zambrano, S. M. Q., & Valencia, D. G. M. (2017)

En la definición anterior se menciona el concepto de amenaza siendo ésta cualquier evento que puede afectar los activos de información y se relaciona, principalmente, con recursos humanos, eventos naturales o fallas técnicas.

El riesgo se utiliza sobre todo el análisis de riesgos de un sistema informático. Este riesgo permite tomar decisiones para proteger mejor al sistema. Se puede

comparar con el riesgo límite que acepte para su activo o recurso tecnológico, de tal forma que, si el riesgo calculado es inferior al de referencia, éste se convierte en un riesgo residual que podemos considerar cómo riesgo aceptable. Zambrano, S. M. Q., & Valencia, D. G. M. (2017).

Activos de información

El término de activo de información se relaciona con todos esos elementos tecnológicos o relacionados con la tecnología que la organización utiliza para el cumplimiento de sus metas o core del negocio. Según la norma ISO/IEC 27001 se entiende como activo todo aquello que es importante y que la organización valora por lo tanto debe de protegerse.

Inventario de activos

De acuerdo a la norma ISO/IEC 27001 es necesario realizar un inventario y clasificación de los activos de información como cumplimiento al Modelo de Seguridad y Privacidad de la Información el cual se estipula de la siguiente forma:



La clasificación de un activo de información se basa en las propiedades de confidencialidad, integridad y disponibilidad como principios para el tratamiento de los datos, en este proceso también evalúa el impacto que tendría en caso de que afectara alguno de estos principios.

Es importante saber que a cada propiedad se le deben establecer criterios específicos acerca de cómo va a ser el tratamiento del activo. Cada entidad puede definir los niveles que permitirán determinar el valor del activo. Normalmente se usan tres niveles: alta, media y baja para saber cuáles activos se deben tratar con prioridad.



Metodologías de valuación de activos

Para la valuación de activos, las metodologías utilizadas son las mismas que se mencionan en la valuación de riesgos informáticos, toda vez que este proceso inicia justamente con la identificación, clasificación y valuación de los activos, por ello es recomendable hacer la selección de una metodología que más se ajuste a la necesidad de cada empresa

La identificación de los activos

Para la realización de este proceso se utilizará como referencia la norma ISO 27001:2017.

Tipos de activos

Los activos los podemos separar en dos grandes grupos: tangibles e intangibles. Los activos tangibles son aquellos activos materiales que contienen información, y sobre los que tomaremos medidas preventivas para protegerlos principalmente de riesgos físicos: golpes, agua, fuego, etc. Los activos intangibles son aquellos que soportan la información dentro de un activo material, y pueden inutilizar la información, pese a que el activo físico no haya sufrido daño alguno.

Activos tangibles o materiales

A continuación, se mencionan algunos ejemplos de los tipos de activos considerados como tangibles:

Equipos informáticos

Servidores físicos

Equipos red local

Periféricos y pendrives

Portátiles, tabletas y móviles

Oficinas e instalaciones

Personal propio

Otros contenedores

Activos intangibles

Entre otros, los siguientes son ejemplos de activos intangibles que puede poseer cualquier organización:

Aplicaciones informáticas

Cualquier software que contenga o gestione información del negocio, será un activo: el ERP, aplicaciones de contabilidad, el CRM, aplicaciones ofimáticas (Word, Excel, PowerPoint), software de control de calidad, aplicaciones de gestión de proyectos o producción, software de nómina, entre otros.

Gestores de copias de seguridad

Sistemas operativos

Comunicaciones

Gestores de bases de datos

Suministros

Actividades para realizar el inventario de activos

*De acuerdo a la norma **ISO 27001** sobre la cual basamos el desarrollo de este componente formativo las siguientes son las actividades que deben de ejecutarse en el proceso de control de los activos informáticos.*



Propiedad de los activos

Los activos de información del inventario deben tener un propietario o responsable. Se recomienda establecer una tabla que permita determinar claramente la siguiente información:



Clasificación de la Información

La información se debería clasificar en función de los requisitos legales, valor, criticidad y susceptibilidad a divulgación o a modificación no autorizada, El sistema de clasificación definido se basa en la confidencialidad como principio rector en la selección e incluye el tratamiento de la información en cuanto a la confidencialidad, la integridad y la disponibilidad de cada activo.

En esta parte se debe agregar a la tabla ya existente de propiedad de los activos la siguiente información:

1. *Tipo de activo de información / Medio*

2. *Copia impresa, archivo electrónico: especificar tipo.*

3. *Medio / dispositivo extraíble: especificar tipo.*

4. *¿Contiene datos personales?*

5. *¿Contiene datos personales Sensibles?*

6. *Confidencialidad (Alta – Media – Baja).*

7. *Disponibilidad (Alta – Media – Baja).*

8. *Integridad (Alta – Media – Baja).*

Tabla 1: Clasificación de acuerdo con la confidencialidad

Confidencial	Acceso restringido a la alta dirección
Restringido	Directores de área y empleados clave tienen acceso.
Interno	Relativo a la información accesible solo los miembros de la organización, pero en cualquier nivel.
Público	Todas las personas, dentro y fuera de la organización, tienen acceso.

Tabla 2: Clasificación de acuerdo a la Integridad

A (Alta)	Información cuya pérdida de exactitud y completitud puede conllevar un impacto negativo de índole legal o económica, retrasar sus funciones, o generar pérdidas de imagen severas de la entidad.
M (Media)	Información cuya pérdida de exactitud y completitud puede conllevar un impacto negativo de índole legal o económica, retrasar sus funciones, o generar pérdida de imagen moderado a funcionarios de la entidad.
B (Baja)	Información cuya pérdida de exactitud y completitud conlleva un impacto no significativo para la entidad o entes externos.
No clasificado	Activos de Información que deben ser incluidos en el inventario y que aún no han sido clasificados, deben ser tratados como activos de información de integridad ALTA.

Tabla 3: Clasificación de acuerdo a la disponibilidad

1 (Alta)	La no disponibilidad de la información puede conllevar un impacto negativo de índole legal o económica, retrasar sus funciones, o generar pérdidas de imagen severas a entes externos.
2 (Media)	La no disponibilidad de la información puede conllevar un impacto negativo de índole legal o económica, retrasar sus funciones, o generar pérdida de imagen moderado de la entidad.
3 (Baja)	La no disponibilidad de la información puede afectar la operación normal de la entidad entes externos, pero no conlleva implicaciones legales, económicas o de pérdida de imagen.
No clasificado	Activos de Información que deben ser incluidos en el inventario y que aún no han sido clasificados, deben ser tratados como activos de información de integridad ALTA.

Etiquetado y manipulación de la información

Se debería desarrollar e implementar un conjunto adecuado de procedimientos para el etiquetado de la información, de acuerdo con el esquema de clasificación de información adoptado por la organización.

- *Se etiquetaron todos los Activos de Información que estén clasificados según el esquema clasificación en Confidencialidad, Integridad y disponibilidad.*
- *Se etiquetará el nivel de clasificación en relación a confidencialidad, integridad y disponibilidad.*

- *Si un Activo de Información en formato impreso no se encuentra etiquetado debe ser tratado en todos sus niveles (Confidencialidad, Integridad y Disponibilidad) como NO CLASIFICADA.*
- *Cada Activo de Información debe ser etiquetado teniendo en cuenta el esquema de clasificación, y en el campo correspondiente diligenciar la clasificación de la siguiente forma: {Clasif.Confidencialidad} - {Clasif.Integridad} - {Clasif.Disponibilidad}.*
- *Para los activos clasificados en confidencialidad se podría utilizar la etiqueta IC, IR, IP, ISC*
- *Para los activos clasificados en integridad como ALTA se utilizará la etiqueta A, MEDIA, M y BAJA, B.*
- *Para los activos clasificados en disponibilidad como ALTA se utilizará la etiqueta 1, MEDIA, 2 y BAJA, 3.*

Evidencia: a continuación, se describe la acción y la correspondiente evidencia que conforma la actividad de aprendizaje.

A partir de la reflexión descrita y con base en lo consultado en el componente formativo elabore un informe detallado en el que describa:

¿Cuáles son los activos tangibles o intangibles informáticos con que cuenta su organización que están relacionados o requeridos para el cumplimiento de los objetivos empresariales?

¿Cómo debe ser la clasificación de la organización?

¿Qué metodologías o estándares puede utilizar para realizar el proceso de valuación de activos?

Por otro lado, teniendo en cuenta el caso de estudio definido en el material de formación, plantee la identificación y clasificación de los activos.

Defina el estándar o el marco de referencia que más se ajusta al estudio de caso.

● Producto a entregar: documento escrito con el informe del análisis y valuación de activos para el caso propuesto.

● Formato: crear un documento y exportarlo a PDF, el cual debe contener portada, informe y bibliografía enmarcada bajo las normas APA.

- *Para hacer el envío del producto remítase al área de la actividad correspondiente y acceda al espacio para el envío de la evidencia AA1_EV01_Informe del análisis y valuación de activos*